

Gestão e Privacidade de Dados

***Nome:** Gabriel Domingues Silva **Turma:** 25E1-2*

Tema: TP1

PROF. HEITOR MELLO
Instituto Infnet

Conteúdo

1	Ponto de Partida	2
1.1	Formatos de Tags e Exemplos de Uso no Mercado	2
1.1.1	Principais formatos de tags:	2
1.1.2	Exemplos de uso no mercado:	2
1.2	Papéis e Responsabilidades no Processo de Classificação e Tratamento das Informações	3
1.2.1	Papéis envolvidos:	3
1.3	Principais Fases de Tratamento das Informações	3
1.4	Diferença entre Mapeamento de Dados e Inventário de Dados	4
2	Estudo de Caso 1 – Inventário de Dados	4
3	Estudo de Caso 2 – Levantamento e Classificação de Informações Empresa MetaData	5

1 Ponto de Partida

1.1 Formatos de Tags e Exemplos de Uso no Mercado

Os formatos de tags são estruturas utilizadas para rotular, identificar e organizar informações em ambientes corporativos. A rotulagem adequada é essencial para classificação, rastreamento e proteção de dados.

1.1.1 Principais formatos de tags:

- **Tags Alfauéricas:** Compostas por letras e números. Exemplo: CL-INF-001 (Classificação: Informação Confidencial, ID 001).
- **Tags Baseadas em Cores:** Utilizam cores para indicar o nível de sensibilidade da informação. Exemplo: VERMELHO para informações sigilosas.
- **Tags Hierárquicas (ou em árvore):** Estruturadas por categorias e subcategorias. Exemplo: Finanças/Relatórios/2025.
- **Tags Temporais:** Indicam a validade ou data de expiração de um dado. Exemplo: EXPIRA:2025-12-31.
- **Tags de Classificação Sensível (usadas em DLP - Data Loss Prevention):** PUBLICO, INTERNO, RESTRITO, CONFIDENCIAL.

1.1.2 Exemplos de uso no mercado:

- **Microsoft Purview (antigo Azure Information Protection):** Utiliza etiquetas como Confidencial, Público, Regulamentado, integradas ao Microsoft 365.
- **Google Workspace:** Permite a criação de etiquetas personalizadas (tags) para e-mails e documentos, como Pessoal, RH, Financeiro.
- **Amazon Web Services (AWS):** Utiliza tags para organização de recursos, como Projeto=CloudMigration ou Ambiente=Produção.

1.2 Papéis e Responsabilidades no Processo de Classificação e Tratamento das Informações

Segundo a **ISO/IEC 27001** e a **ISO/IEC 27002**, o processo de classificação e tratamento da informação exige definição clara de papéis e responsabilidades.

1.2.1 Papéis envolvidos:

- **Proprietário da Informação (Information Owner):**
 - Define o nível de classificação da informação.
 - Aprova o uso e o compartilhamento dos dados.
 - Responsável pela integridade e atualização da informação.
- **Usuário da Informação (Information User):**
 - Acessa e utiliza as informações conforme os níveis de permissão.
 - Reporta incidentes de segurança ou uso indevido.
- **Administrador de Sistemas/Segurança da Informação:**
 - Garante os controles técnicos de acesso e proteção dos dados.
 - Implementa soluções de criptografia, DLP e monitoramento.
- **Data Protection Officer (DPO) ou Encarregado de Dados (LGPD):**
 - Supervisiona o tratamento adequado de dados pessoais.
 - Atua como canal entre a organização, os titulares dos dados e a ANPD.

1.3 Principais Fases de Tratamento das Informações

De acordo com a **Lei Geral de Proteção de Dados (LGPD)** e normas ISO como a **ISO/IEC 27701**, o tratamento de informações compreende diversas fases. Abaixo estão as principais:

1. **Coleta:** Recebimento dos dados, podendo ser de forma direta (formulários, cadastros) ou indireta (cookies, sensores).
2. **Armazenamento:** Guarda segura da informação, respeitando políticas de retenção e criptografia.
3. **Uso:** Utilização para as finalidades previamente definidas e consentidas.
4. **Compartilhamento:** Transferência de dados entre departamentos ou para terceiros, devendo obedecer aos princípios da minimização e necessidade.
5. **Eliminação ou descarte:** Quando os dados deixam de ser necessários ou expira a base legal, devem ser eliminados de forma segura.
6. **Auditoria e Monitoramento:** Avaliação contínua dos processos para garantir conformidade com normas e leis.

1.4 Diferença entre Mapeamento de Dados e Inventário de Dados

Mapeamento de Dados (Data Mapping):

Processo técnico que identifica como os dados fluem dentro da organização. Visa entender a origem, transformação e destino dos dados.

- **Objetivo:** Documentar fluxos de dados (data flow), conexões entre sistemas, integrações e pontos de vulnerabilidade.
- **Exemplo:** Dado coletado via app → processado em servidor interno → enviado à nuvem → compartilhado com parceiro.

Ferramentas comuns: Microsoft Purview, Collibra, OneTrust.

Inventário de Dados (Data Inventory):

Catálogo estruturado de todos os ativos de informação da empresa, com suas classificações, localização, base legal, e finalidade.

- **Objetivo:** Permitir governança e rastreabilidade sobre os dados armazenados e tratados.
- **Exemplo:** Nome do ativo: Base de clientes 2024; Tipo: Dados pessoais; Local: Servidor interno X; Finalidade: Marketing.

Diferencial entre os dois:

- **Mapeamento:** Foca no “caminho” que o dado percorre.
- **Inventário:** Foca em “o que” está sendo armazenado e tratado.

Ambos são essenciais para:

- Cumprimento da **LGPD** (art. 37 – registro das atividades de tratamento).
- Implementação eficaz da **ISO/IEC 27701** e controles do **Anexo A da ISO/IEC 27002**.

2 Estudo de Caso 1 – Inventário de Dados

A construção de um inventário de dados é essencial para a governança da informação e conformidade com a **Lei Geral de Proteção de Dados (LGPD)**. A tabela a seguir apresenta 6 informações críticas para esse processo, suas descrições e exemplos práticos.

Informação	Descrição	Exemplo 1	Exemplo 2	Observações
Nome do Ativo	Nome do conjunto de dados ou sistema que armazena informações	Base de Dados de Clientes	Sistema de Folha de Pagamento	Identificação do ativo facilita rastreabilidade.
Tipo de Dado	Categoria da informação armazenada (pessoal, sensível, financeiro etc.)	Dados Pessoais	Dados Financeiros e de Saúde	Define o nível de proteção necessário.
Finalidade do Tratamento	Razão pela qual o dado é coletado, armazenado ou processado	Marketing Direto	Gestão de Benefícios de Funcionários	Fundamenta a base legal do tratamento.
Base Legal	Fundamento jurídico que autoriza o tratamento (consentimento, contrato etc.)	Consentimento do Titular	Execução de Contrato Trabalhista	Alinhada com o art. 7º da LGPD.
Responsável pelo Dado	Pessoa ou departamento que administra e garante a conformidade da informação	Departamento de Marketing	Recursos Humanos	Papel alinhado à ISO/IEC 27001 e 27701.
Local de Armazenamento	Onde o dado é mantido, fisicamente ou em nuvem	Servidor Local (Data Center)	Google Workspace (nuvem)	Essencial para análise de risco e segurança.

Tabela 1: Informações utilizadas na construção de um Inventário de Dados

3 Estudo de Caso 2 – Levantamento e Classificação de Informações Empresa MetaData

A tabela a seguir apresenta informações extraídas do processo de desenvolvimento da MetaData, com respectivos responsáveis e classificações segundo os projetos ProntoMed e PJ-SToC-2025:

Informação	Descrição	Gestor	Custodiante	Classificação ProntoMed	Classificação PJ-SToC-2025
Relatório de Requisitos	Documento contendo requisitos funcionais e não funcionais definidos com o cliente	Gerente de Projetos	Setor de TI	Confidencial	Sensível
Código Fonte	Scripts e módulos do software armazenados em biblioteca de software da TI	Coordenador de Desenvolvimento	Setor de Desenvolvimento	Confidencial	Sensível
Documentos de Homologação	Registro formal da aprovação das funcionalidades desenvolvidas pelo cliente	Gerente de Projetos	Setor de TI	Sensível	Restrito
Relatório de Implementação	Relatório eletrônico de implantação de funcionalidades enviado ao cliente	Coordenador Técnico	Setor de TI	Sensível	Restrito
Emails de Comunicação	Comunicação com cliente sobre entregas, aprovações e atualizações	Gerente de Projetos	Setor de TI	Restrito	Restrito
Planejamento do Projeto	Documento com cronograma, recursos e marcos de entrega dos projetos	Gerente de Projetos	Setor de Desenvolvimento	Confidencial	Sensível

Tabela 2: Levantamento e Classificação de Informações da Empresa MetaData